HSLU Hochschule Luzern

SW02 TOM, OSINT

Privatheit, Technologie und Datenschutz



Dozent: Dr. Radwan Eskhita

Informatik
FS2026

FH Zentralschweiz

Vorlesungsagenda

Thema
• Privacy Enhancing Technologies • Technische, Organizatorische Massnahmen • Privacy by Design
Pause
Gast Dotzentin: Dr. Alana Gramm – IBM Deutschland • Open Source Intelligence (OSINT) • Übungen • Überblick nächste Lektion (SW4)

Restlicher Inhalt von SW01

HSLU

Privacy – Gesetze und Standards

Legislation and Regulation

EU GDPR

Europäische Datenschutz-Grundverordnung mit weitreichenden

Auswirkungen auch auf Schweizer Unternehmen

revDSG Schweiz

Revidiertes Datenschutzgesetz der Schweiz, das 2023 in Kraft trat

Standards

ISO 27000 (Security Management)

Data Security



- Vertraulichkeit
- Integrität
- Verfügbarkeit
- Authentifizierung
- Autorisierung
- Abrechnung

Implementing Data Protection

- Kontrolle über persönliche Daten
- Datenminimierung
- Identitätsmanagement
- Rechtskonforme Verarbeitung von Daten

Leonardo A. Martucci, Karlstadt

Ein effektiver Datenschutz erfordert sowohl rechtliche als auch technische Massnahmen, die ineinandergreifen und sich gegenseitig ergänzen.

HSLU

Privacy – Gesetze und Standards



HIPAA

US-amerikanisches Gesetz zum Schutz von Gesundheitsdaten (1996).

- Regelt die Speicherung, Übertragung und Offenlegung von personenbezogenen Gesundheitsinformationen (PHI).
- Legt Standards für den Umgang mit Gesundheitsdaten fest, insbesondere für Gesundheitsdienstleister, Versicherungen und deren Partner.
- Fordert strenge Sicherheitsvorkehrungen zum Schutz der Vertraulichkeit und Integrität von Gesundheitsdaten.
- **45 C.F.R. § 164.514(b)** of the HIPAA Privacy Rule.

CCPA
California Consumer Privacy Act

Kalifornisches Datenschutzgesetz, das 2020 in Kraft trat.

Verbraucherrechte

Gewährleistet den Verbrauchern das Recht auf Kontrolle über ihre personenbezogenen Daten.

Geschützte Daten

Schützt Daten wie Namen, Adressen, IP-Adressen, Kaufverhalten und mehr.

Anwendungsbereich

Gilt für Unternehmen, die in Kalifornien tätig sind und bestimmte Schwellenwerte überschreiten.

HSLU

Case Study: Temu

Hintergrund

Temu, ein Online-Marktplatz, ist derzeit die meistgeladene kostenlose App in den iOS- und Google-App-Stores.

Datenschutzrichtlinie und automatische Datensammlung

Temus Datenschutzrichtlinie fällt durch subtile, indirekte Methoden auf, die möglicherweise zur Nachverfolgung von Nutzern führen.

Ein wichtiger Abschnitt beschreibt die "automatische Datensammlung". Hierbei wird aufgeführt, welche Informationen das Unternehmen ohne ausdrückliche Zustimmung des Nutzers erhebt:

- Betriebssystemtyp und -version
- Hersteller und Modell
- Browsertyp
- Bildschirmauflösung
- RAM- und Festplattengrösse
- CPU-Auslastung
- Gerätetyp
- IP-Adresse
- Eindeutige Kennungen (einschliesslich Werbe-IDs)
- Allgemeine Standortinformationen



HSLU

Case Study: Temu

Anonymisierung und Re-Identifizierung

> Obwohl Temu eine sehr breite Nutzung der gesammelten Daten beansprucht, wird behauptet, die Daten zu anonymisieren, ohne konkrete Details zu liefern.
>
> Wir können Ihre personenbezogenen Daten für Forschungs- und Entwicklungszwecke verwenden, einschliesslich zur Analyse und Verbesserung unseres Dienstes und unseres Geschäfts.

Der Prozess der Anonymisierung ist jedoch entscheidend. Studien haben gezeigt, dass Standort- und Kaufdaten häufig ausreichen, um Individuen erneut zu identifizieren.

Experteneinschätzung

Laut Calli Schroeder, Datenschutzanwältin bei EPIC (Electronic Privacy Information Center), entfernen de-identifizierte Daten zwar explizite Identifikatoren, enthalten jedoch oft mehrere persönliche Datenelemente, die über eine Nummer statt eines Namens mit einer Person verknüpft werden können.

Diese Case Study verdeutlicht, wie wichtig es ist, Datenschutzrichtlinien kritisch zu lesen und zu verstehen, welche Daten Apps und Webseiten sammeln und wie diese verwendet werden. Die behauptete Anonymisierung bietet oft keinen ausreichenden Schutz vor Re-Identifizierung.

HSLU

Case Study

- Ein neuer Hinweis besagt:
- Bitte beachten Sie, dass wir unseren Drittanbieter-Werbepartnern nicht gestatten, personenbezogene Daten für Werbezwecke aus der TEMU für iOS-Geräte zu sammeln.

Fazit

- Die Datenschutzpraktiken von TEMU verdeutlichen die Herausforderungen bei der Transparenz und der tatsächlichen Anonymisierung von Nutzerdaten. Trotz angeblicher Massnahmen zur Anonymisierung bleiben erhebliche Datenschutzrisiken bestehen.
- Temu reagierte nicht auf Anfragen zur Stellungnahme.

Opt-out reicht aus?

Merkmal	Schweiz (nDSG)	EU (DSGVO)
Standard-Cookies	Meist **Opt-out** (Banner mit Info & Widerspruch)	**Opt-in** zwingend erforderlich
Sensible Daten	**Opt-in** erforderlich	**Opt-in** erforderlich
Newsletter	**Opt-in** (wegen UWG)	**Opt-in**
Fokus	Transparenz & Treu und Glauben	Explizite Einwilligung



HSLU

Lernziele

1 **Informationen kombinieren verstehen**

Erkennen, wie scheinbar harmlose öffentliche Informationen zusammengefügt werden können, um private Details über Personen preiszugeben.

2 **OSINT-Tools praktisch anwenden**

Praktische Erfahrung mit Tools von tools.myosint.training und anderen Aufklärungsplattformen sammeln.

3 **Datenschutzrisiken bewerten**

Die Gefahren von Datenlecks und übermässigem Teilen auf Social-Media-Plattformen einschätzen.

4 **Privacy by Design, PET und solche Begriffe kennenlernen**

HSLU

Privacy Enhancing Technologies



HSLU

Was sind Privacy Enhancing Technologies (PETs)?

Privacy Enhancing Technologies sind Technologien, die die Verarbeitung von Daten so gestalten, dass der Datenschutz maximiert wird, ohne den Zweck der Datenbearbeitung übermässig einzuschränken.

Ziel von PETs

- Gesetzliche Vorgaben wie Datensparsamkeit technisch unterstützen
- Zweckbindung und Transparenz gewährleisten
- Vertraulichkeit sicherstellen
- Risiken für betroffene Personen minimieren

Warum PETs?

Datenschutzgesetze (DSG, DSGVO) verlangen technische und organisatorische Massnahmen (TOM). Viele Risiken entstehen nicht aus „klassischen Hacks", sondern durch problematische Datenverarbeitung. PETs mindern diese Risiken auf technischer Ebene, oft schon im Designstadium.

Typische Risiken ohne PETs: Re-Identifikation in anonymisierten Daten, Profilbildung durch Tracking, Datenabfluss an Dritte bei Cloud-Speicherung

HSLU

Klassische PETs: Kategorien & Beispiele

Datenminimierung & Maskierung

Daten so früh wie möglich anonymisieren oder pseudonymisieren

Beispiel: Logging ohne IP-Adresse, nur mit Hashes

Kontrolle & Transparenz

Privacy Dashboards ermöglichen Nutzern zu sehen, wer ihre Daten nutzt und wofür

Beispiel: Google "My Activity", Consent-Management-Systeme wie Usercentrics

Anonyme Nutzung

Technische Verfahren für anonyme Kommunikation und Nutzung

Beispiel: TOR/Onion Routing für anonymes Surfen, Mix-Nets für anonyme Kommunikation

HSLU

Geeignete PETs & Beispiele

Verkehrsflussdaten-Beispiel

01

Differential Privacy

Statistisches Rauschen verhindert Rückschluss auf einzelne Wege. Verkehrsflussdaten werden leicht „gestört", ohne das Muster zu verzerren.

02

Geo-Fencing / Blacklisting

Bereiche mit hohem Risiko (Krankenhäuser, Wohnviertel) werden von Auswertung ausgeschlossen. Bewegungen in Wohnstrassen tauchen in öffentlichen Berichten nicht auf.

03

Thresholding

Ergebnisse werden nur publiziert, wenn genug Verkehrsteilnehmer gezählt wurden. Mindestens 50 Autos/Tag auf einer Strasse, bevor Daten gezeigt werden.

HSLU

Technische & Organisatorische Massnahmen



HSLU

Datenschutz technisch & organisatorisch sicherstellen

DSGVO Art. 32 & DSG Art. 8 Abs. 1: Personendaten müssen durch angemessene technische und organisatorische Massnahmen (TOM) gegen unbefugte Bearbeitung geschützt werden.

Organisatorische Massnahmen

- Schulungen & Awareness-Programme
- Rollen & Verantwortlichkeiten definieren
- Notfallpläne & Incident Response
- Compliance-Management

Technische Massnahmen

- End-to-End-Verschlüsselung
- Zugriffskontrollen & Protokollierung
- Pseudonymisierung & Anonymisierung
- Sichere Datenarchitekturen

Praxisbeispiel: AWS Whitepaper dokumentiert und zertifiziert umfassende Cloud-TOMs für verschiedene Compliance-Anforderungen.

HSLU

Technische und organisatorische Massnahmen (TOMs)

- **Zutrittskontrolle**

  Physischer Schutz von Datenverarbeitungsanlagen (verschlossene Türen, Sicherheitszonen)

- **Zugangskontrolle**

  Computer- und Systemzugriff nur mit Authentifizierung (Passwortschutz, 2FA)

- **Zugriffskontrolle**

  Datenzugriff nur gemäss Berechtigungskonzept (Role-Based Access Control)

- **Weitergabekontrolle**

  Protokollierung bei elektronischem Datentransport (Audit-Logs, Verschlüsselung)

- **Eingabekontrolle**

  Eingabe personenbezogener Daten nur durch autorisiertes Personal

- **Auftragskontrolle**

  Verarbeitung nur gemäss erteiltem Auftrag und definierten Prozessen

- **Verfügbarkeitskontrolle**

  Schutz gegen zufällige Zerstörung oder Verlust durch Backup-Systeme

- **Gebot der Datentrennung**

  Zu unterschiedlichen Zwecken erhobene Daten werden getrennt verarbeitet

HSLU

TOM im Detail: Zugangskontrolle & Sicherheit

Zugangskontrolle

Unbefugten den Zutritt zu Datenverarbeitungsanlagen verwehren und verhindern, dass unbefugte Personen auf Systeme und Daten zugreifen.

- Multi-Faktor-Authentifizierung (2FA/MFA)
- Role-Based Access Control (RBAC)
- Starke Passwort-Richtlinien mit Hashing

Verschlüsselung & Übertragung

Sichere Datenübertragung und -speicherung durch moderne kryptographische Verfahren.

- Verschlüsselung in Transit (TLS/SSL, VPN, SFTP, IPSec)
- Logging von Datenübertragungen
- Audit-Logs und unveränderliche Protokolle

Dokumentation & Nachverfolgung

Revisionssichere Dokumentation aller datenschutzrelevanten Aktivitäten.

- Revisionssichere Speicherung (WORM-Medien)
- Zeitstempelung und Benutzer-IDs bei Änderungen
- SIEM-Systeme für Monitoring

HSLU

TOM im Detail: Verfügbarkeit & Sicherheit

Verfügbarkeitskontrolle & Belastbarkeit

Schutz vor zufälliger Zerstörung, Verlust oder Ausfall der Systeme

- Redundante Hardware & Failover-Cluster
- RAID-Systeme und USV
- Disaster Recovery Pläne

Network Security

- IDS/IPS (Snort, Suricata)
- Zero-Trust-Netzwerke
- Network Segmentation

Privacy by Design/Default

- Datenminimierung
- Pseudonymisierung
- Anonymisierung

Monitoring & Response

Kontinuierliche Überwachung auf verdächtige Aktivitäten und automatisierte Incident-Response-Mechanismen

Technische Maßnahmen	Organisatorische Maßnahmen
☐ Alarmanlage	☐ Schlüsselregelung / Liste
☐ Automatisches Zugangskontrollsystem	☐ Empfang / Rezeption / Pförtner
☐ Biometrische Zugangssperren	☐ Besucherbuch / Protokoll der Besucher
☐ Chipkarten / Transpondersysteme	☐ Mitarbeiter- / Besucherausweise
☐ Manuelles Schließsystem	☐ Besucher in Begleitung durch Mitarbeiter
☐ Sicherheitsschlösser	☐ Sorgfalt bei Auswahl des Wachpersonals
☐ Schließsystem mit Codesperre	☐ Sorgfalt bei Auswahl Reinigungsdienste
☐ Absicherung der Gebäudeschächte	☐
☐ Türen mit Knauf Außenseite	☐
☐ Klingelanlage mit Kamera	☐
☐ Videoüberwachung der Eingänge	☐
☐	☐
☐	☐
☐	☐

HSLU

AWS als Beispiel für dokumentierte TOMs

AWS veröffentlicht regelmässig umfassende Security & Compliance Whitepaper, die detailliert die implementierten TOMs in AWS-Rechenzentren und -Services beschreiben.



AWS Risk and Compliance Whitepaper (PDF)



Technische Massnahmen

- Verschlüsselung: KMS (Key Management Service), TLS 1.3
- Monitoring: AWS CloudTrail, GuardDuty
- Zugriffskontrolle: IAM (Identity & Access Management)

Dokumentation & Compliance

Enthält technische Details, Prozesse und Zertifikate für verschiedene Compliance-Frameworks.

AWS Risk and Compliance Whitepaper (PDF)

HSLU

Organisatorische Massnahmen & Zertifizierungen

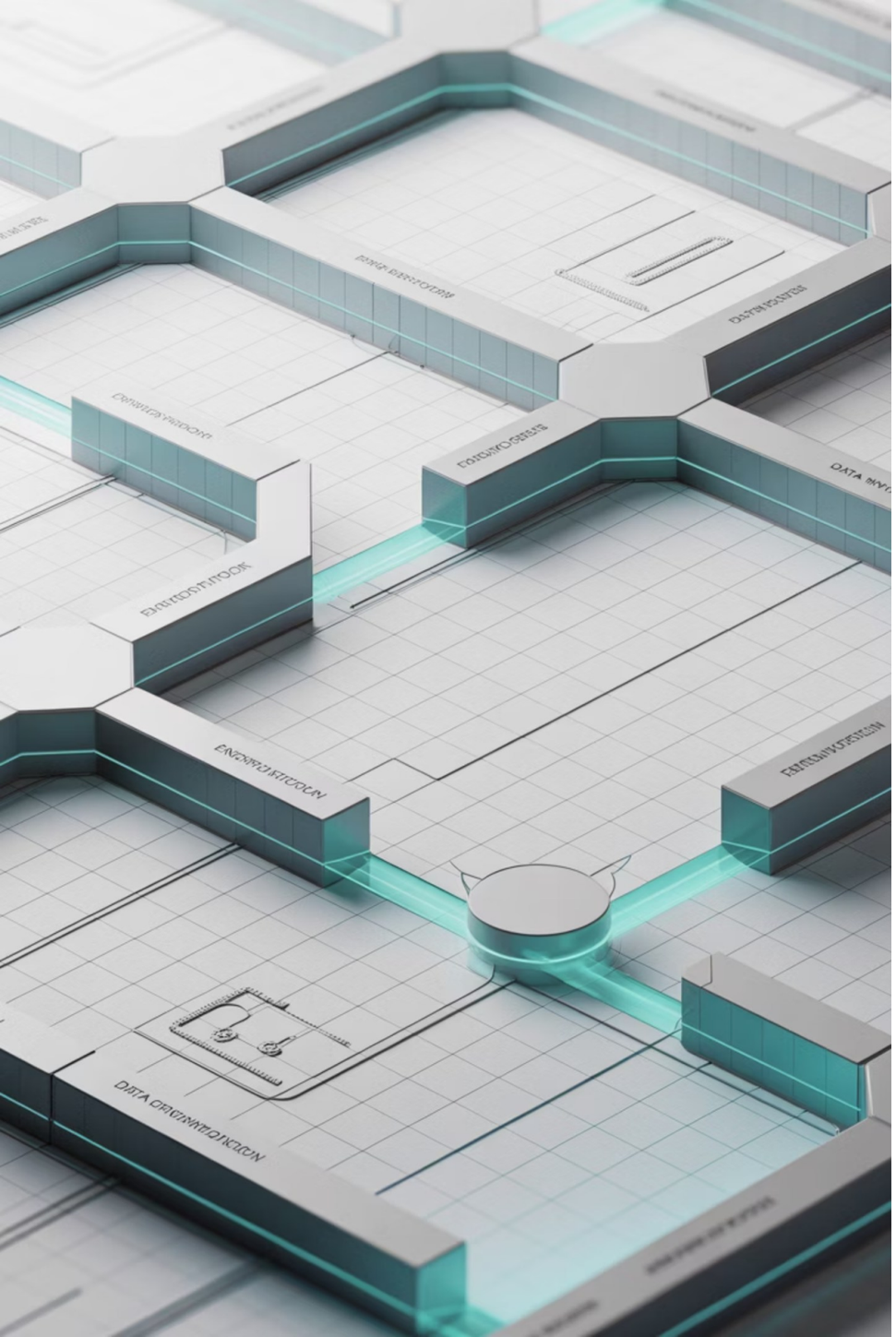
Organisatorische Massnahmen

- Rechenzentrums-Sicherheitszonen
- Strenge Zutrittskontrollen
- 24/7 Incident Response
- Regelmässige Mitarbeiterschulungen
- Awareness-Programme

Internationale Zertifizierungen

- **ISO/IEC 27001** – Informationssicherheits-Management
- **ISO/IEC 27701** – Privacy Information Management
- **SOC 1, SOC 2, SOC 3** – Service Organization Controls
- **C5 (BSI)** – Cloud Computing Compliance

Nützliche Links: AWA Compliance Program| LINK: TOM prüfen online
Verhaltenskodizes (Art. 11 DSG, Art. 12 DSV). ILIAS



HSLU

Privacy by Design

HSLU

Datenschutz durch Technikgestaltung

Privacy by Design (PbD) ist ein Rahmenkonzept, das die Integration von Datenschutzaspekten in die Gestaltung und Entwicklung von Produkten, Dienstleistungen und Systemen fördert.

Es betont **proaktive Massnahmen**, um Datenschutzmassnahmen von Anfang an in die Architektur dieser Entitäten einzubetten, anstatt Datenschutz als nachträgliche Überlegung oder optionales Feature zu behandeln.

Privacy by Default ist ein Grundsatz innerhalb des PbD-Rahmens, der sich dafür einsetzt, dass Datenschutzeinstellungen standardmässig auf ihre datenschutzfreundlichste Option für Benutzer konfiguriert werden.

Dies bedeutet, dass die Privatsphäre von Einzelpersonen standardmässig geschützt wird und sie aktiv wählen müssen, um sich für weniger datenschutzfreundliche Einstellungen zu entscheiden.

HSLU

DSGVO Artikel 25: Datenschutz durch Technikgestaltung

Auswahl und Gestaltung von Datenverarbeitungssystemen sollen an dem Ziel ausgerichtet sein, so wenig Daten wie möglich zu erheben, zu verarbeiten oder zu nutzen (Grundsatz der Datenvermeidung und Datensparsamkeit).

Datenminimierung

Die Verarbeitung personenbezogener Daten minimieren

Pseudonymisierung

Personenbezogene Daten so schnell wie möglich pseudonymisieren

Transparenz

Transparenz in Bezug auf Funktionen und Verarbeitung personenbezogener Daten herstellen

Überwachung

Betroffenen Personen ermöglichen, die Verarbeitung zu überwachen

Sicherheitsfunktionen

Verantwortliche in die Lage versetzen, Sicherheitsfunktionen zu schaffen und zu verbessern

Eine einzelfallbezogene Abwägung zwischen den Risiken und zumutbaren Möglichkeiten der Umsetzung hat zu erfolgen. Genehmigte Zertifizierungsverfahren gemäss Artikel 42 können als Nachweis herangezogen werden.

HSLU

Schweizer DSG Artikel 7: Privacy by Design

Datenschutz durch Technik und datenschutzfreundliche Voreinstellungen

Absatz 1: Verpflichtung zur Ausgestaltung

Der Verantwortliche ist verpflichtet, die Datenbearbeitung technisch und organisatorisch so auszugestalten, dass die Datenschutzvorschriften eingehalten werden.

Absatz 2: Angemessenheit der Massnahmen

Die technischen und organisatorischen Massnahmen müssen insbesondere dem Stand der Technik, der Art und dem Umfang der Datenbearbeitung angemessen sein.

Absatz 3: Datenschutzfreundliche Voreinstellungen

Der Verantwortliche ist verpflichtet, mittels geeigneter Voreinstellungen sicherzustellen, dass die Bearbeitung der Personendaten auf das für den Verwendungszweck nötige Mindestmass beschränkt ist.

HSLU

Privacy by Design - Technische Umsetzung



Anonymity

- Onion Routing (TOR)
- Anonymous Credentials (Zero-Knowledge Proofs)
- Anonymisierung (k-Anonymität, l-Diversität)



Privacy-preserving Computations

- Search over Encrypted Data (Keywords, Order-preserving)
- Homomorphic Encryption
- Secure Multi-party Computation



Privacy Policies

- Private Information Retrieval (PIR)
- Differential Privacy
- Policy-based Access Control

HSLU

Privacy by Design Tool: Databunker

Ein Open-Source-Tool, das speziell entwickelt wurde, um sensible Benutzerdaten sicher zu speichern und Datenschutzbestimmungen wie die DSGVO und das revidierte DSG zu erfüllen.

Überblick & Links

- Databunker Homepage

Szenario

Ein mittelständisches Unternehmen möchte eine neue Datenbank für Kundendaten einrichten, die höchsten Datenschutzstandards entspricht und gesetzliche Vorschriften einhält.

Kernfunktionen

- **Automatische Verschlüsselung** von gespeicherten Daten
- **API-Unterstützung** für einfache Integration
- **Audit Logs** für alle Datenzugriffe
- **Privacy Requests Management** für DSGVO-Anfragen



HSLU

Databunker: Herausforderungen & Lösungsansatz

Herausforderung 1: Zugriffskontrollen

Sicherstellung, dass nur autorisierte Nutzer Zugriff auf sensible Daten haben

Herausforderung 2: Datenschutzanfragen

Einführung einer zentralisierten Plattform für Auskunfts- und Löschungsanfragen

Herausforderung 3: Datenschutzverletzungen

Minimierung durch Verschlüsselung und strenge Zugriffskontrollen

Herausforderung 4: Integration

Erleichterung der Integration in bestehende Systeme

Herausforderung 5: Compliance

Einhaltung von Datenschutzrichtlinien (revDSG, GDPR)

Lösung: Databunker bietet eine End-to-End-Lösung für die sichere Speicherung von personenbezogenen Daten (PII), speziell abgestimmt auf die Anforderungen von Datenschutzgesetzen.

HSLU

Open-Source Intelligence (OSINT)



OSINT und Datenschutz: Wenn öffentliche Informationen private Risiken erzeugen

Open Source Intelligence (OSINT) bildet die Schnittstelle zwischen öffentlich zugänglichen Informationen und Ihrer Privatsphäre. Dieser Vortrag zeigt, wie Daten, die isoliert harmlos wirken, durch systematische Analyse erhebliche Datenschutzrisiken bergen können. Ein fundiertes OSINT-Verständnis ist für Juristen, IT-Experten und Datenschutzbeauftragte unerlässlich, um in der komplexen digitalen Landschaft proaktiv zu handeln.

HSLU

EINFÜHRUNG IN DAS MODUL

OSINT verstehen: Praktische Einblicke

Definition und Anwendungsbereich

OSINT ist das gezielte Sammeln, Verarbeiten und Analysieren von Informationen aus öffentlich zugänglichen Quellen. Es nutzt ausschliesslich Material, das jedermann legal einsehen kann.

OSINT verwandelt verstreute öffentliche Informationen durch strukturierte Analyse in verwertbare Erkenntnisse.

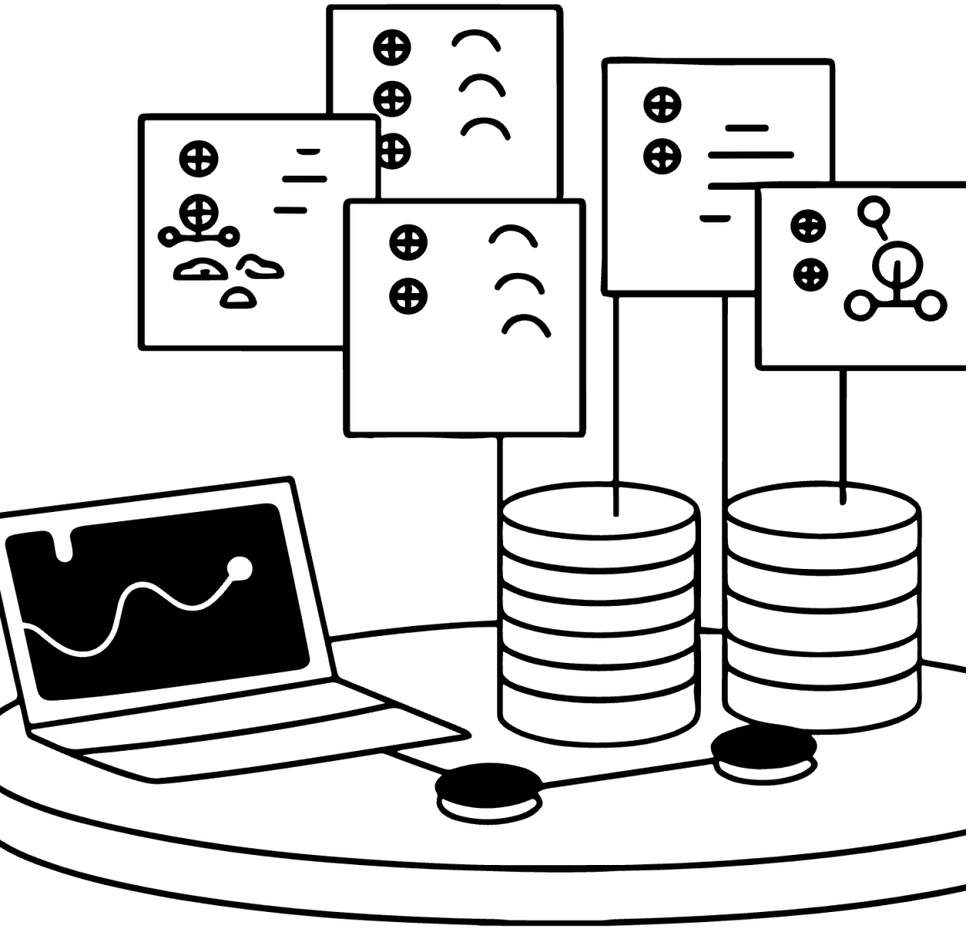
Kernprinzip

Öffentlich zugänglich ≠ harmlos

Zugänglichkeit bedeutet nicht Sicherheit oder mangelnde Sensibilität.

Ihre Relevanz

Zentral für Ihren Datenschutz, Ihre Cybersicherheit und Ihre digitalen Rechte.



Was ist OSINT?

Open-Source Intelligence (OSINT) bezeichnet die systematische Sammlung und Analyse öffentlich zugänglicher Informationen zur Generierung verwertbarer Erkenntnisse.

Wichtige Quellen

- Social Media Plattformen
- Suchmaschinen und Archive
- Öffentliche Register (Handelsregister)
- Websites, Blogs und Foren
- Technische Datenbanken (WHOIS, IP-Adressen)

Konsequenzen & Risiken

- Datenschutzverletzungen bei unsachgemässer Handhabung
- Rechtliche Grenzen (DSGVO, Strafrecht)
- Missbrauchspotenzial durch Dritte

Anwendungsbereiche

- Ermittlungsarbeit und Kriminalistik
- Cybersicherheit und Threat Intelligence
- Journalismus und Recherche

Wichtige Prinzipien

- Legalität und Verhältnismässigkeit prüfen
- Quellen transparent dokumentieren
- Objektivität wahren und Vorurteile vermeiden
- Privatsphäre und Persönlichkeitsrechte respektieren

HSLU

Öffentliche Daten und der Schutz Ihrer Privatsphäre

Warum „freiwillige“ Datenfreigabe problematisch ist

Oft wird angenommen, dass Online-Datenteilung den Datenschutz aufhebt. Diese Sichtweise übersieht jedoch wichtige Aspekte:

- Plattformregeln und Datennutzung ändern sich ständig.
- Nutzer wissen weniger über Datennutzung als Datensammler.
- Echte Zustimmung fehlt oft.

Die Annahme 'freiwilliger Offenlegung' ignoriert Machtungleichgewichte und Informationsdefizite in der digitalen Welt.

Kontextkollaps: Ein Hauptrisiko für Ihre Privatsphäre

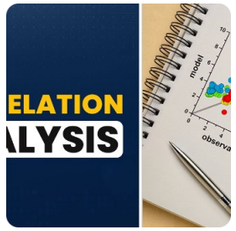
Kontextkollaps: Für einen Zweck geteilte Informationen werden aus ihrem Kontext gerissen und in völlig neuen Zusammenhängen gedeutet.

Beispiel: Ein privates Foto kann durch systematische Analyse berufliche Zugehörigkeiten, Bewegungsmuster oder politische Ansichten offenbaren.
Isolierte Datenpunkte, die harmlos erscheinen, können durch Zusammenführung und Korrelation sensible Profile von Personen erstellen.

HSLU

OSINT als Bedrohung für Ihre Privatsphäre

OSINT (Open Source Intelligence) birgt ein Datenschutzrisiko, da scheinbar harmlose Datenpunkte durch systematische Analyse zu umfassenden persönlichen Profilen werden können.



Profilbildung durch Datenkorrelation

Die Zusammenführung von Informationen aus verschiedenen Quellen erstellt detaillierte Profile, die Überzeugungen, Zugehörigkeiten, finanzielle Lage, Gesundheitszustände und persönliche Beziehungen offenbaren.



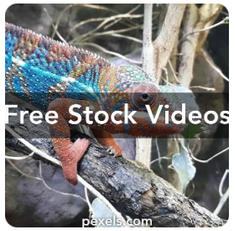
Re-Identifizierung trotz Anonymisierung

Selbst anonymisierte Datensätze können durch Abgleich mit öffentlichen Informationen re-identifiziert werden und machen Anonymisierungsbemühungen zunichte.



Standortverfolgung ohne GPS

Metadaten von Fotos, Check-in-Muster, WLAN-Netzwerk-IDs und Social-Media-Beiträge ermöglichen präzise Standortverfolgung ohne direkte GPS-Daten.



Ableitung von Verhaltensmustern

Die Analyse zeitlicher Muster in Online-Aktivitäten enthüllt tägliche Routinen, Arbeitszeiten, soziale Beziehungen und Lebensstilpräferenzen.

HSLU

TECHNISCHE ANALYSE

Technische Dimensionen von OSINT



Modernes OSINT nutzt technische Fähigkeiten zur automatisierten Sammlung, Verarbeitung und Analyse grosser Mengen öffentlicher Daten, um schnell umfassende Einblicke zu gewinnen.

https://geospy.net
https://www.metadata2go.com/view-metadata

Methoden für technisches OSINT

Metadaten-Extraktion: EXIF-Daten (Bilder) und Dokumentmetadaten enthüllen Kameramodelle, GPS, Zeitstempel, Software, Autoren und Revisionshistorien.

Umgekehrte Bildsuche: Dienste wie Google Bilder und TinEye zeigen, wo Bilder online erscheinen. So entdecken Sie alternative Benutzernamen, Orte und kontextbezogene Infos.

Benutzernamen-Korrelation: Verknüpfung einzigartiger Benutzernamen über Plattformen hinweg erstellt umfassende digitale Fussabdrücke aus fragmentierten Identitäten.

Automatisierte OSINT-Tools: Software wie Maltego ermöglicht automatisierte Datenerfassung und Beziehungsanalyse im grossen Massstab, was manuell nicht möglich wäre.

HSLU

RECHTLICHE VORGABEN

OSINT und Datenschutz: Ihre rechtlichen Pflichten

OSINT-Aktivitäten sind eng mit Datenschutzgesetzen verknüpft, was Fragen zu den rechtlichen Grenzen der Informationsbeschaffung und -verarbeitung aufwirft. Das revidierte Schweizer Datenschutzgesetz (revDSG) und die EU-Datenschutz-Grundverordnung (DSGVO) bilden hierfür die relevanten Rahmenbedingungen.

Personenbezogene Daten durch Zusammenführung

Informationen gelten als personenbezogene Daten, wenn sie sich auf eine identifizierte oder identifizierbare natürliche Person beziehen. OSINT erzeugt diese oft durch die Kombination öffentlich zugänglicher Daten, die einzeln keine Identifizierung ermöglichen.

Zweckbindung und Verhältnismässigkeit prüfen

Zweckbindung (Artikel 5(1)(b) DSGVO / Artikel 6(3) revDSG): Daten, die für einen Zweck erhoben wurden, dürfen nicht beliebig umfunktioniert werden. OSINT kann dagegen verstossen, wenn öffentlich geteilte Informationen für Überwachung, Profiling oder kommerzielle Auswertung zweckentfremdet werden.

- **Rechtliche Grauzonen verstehen:** Viele OSINT-Aktivitäten bewegen sich in rechtlich unklarem Terrain. Öffentlich verfügbare Informationen können die Privatsphäre verletzen, wenn sie automatisiert und im grossen Massstab gesammelt werden. Gerichte anerkennen zunehmend, dass Legalität allein keine Legitimität gewährleistet. Seien Sie sich dieser Risiken bewusst und handeln Sie proaktiv.

HSLU

OSINT und Bedrohungsanalyse

Das Verständnis, wie Angreifer OSINT (Open Source Intelligence) nutzen, ist entscheidend für wirksame Sicherheits- und Datenschutzstrategien. Bedrohungsakteure steigern die Raffinesse und Erfolgsquote ihrer Angriffe mit öffentlich zugänglichen Informationen.



Social Engineering

Angreifer nutzen OSINT, um persönliche Details für glaubwürdige Identitätsdiebstahl-Versuche zu sammeln



Doxxing

Böswillige Veröffentlichung privater, durch OSINT zusammengetragener Informationen, um Einzelpersonen zu belästigen, einzuschüchtern oder weitere Angriffe zu erleichtern.



Stalking und physische Bedrohungen

OSINT-Daten zu Standort, Routine und Beziehungen ermöglichen physische Überwachung und stellen direkte Sicherheitsrisiken für Zielpersonen dar.



Wirtschaftsspionage

Konkurrenten nutzen OSINT, um Informationen über Geschäftsstrategien, Partnerschaften, Kompetenzen und Methoden zu sammeln, ohne illegale Eingriffe vorzunehmen.

HSLU

Verantwortlichkeiten in Organisationen und für Einzelpersonen

Strategische Ansätze für OSINT-Risiken

Effektives OSINT-Risikomanagement erfordert die Kombination aus technischer Gestaltung, Unternehmensrichtlinien und individuellem Verhalten. Technologische Lösungen oder reine Anwenderschulungen genügen nicht.

Privacy by Behaviour: Jeder Einzelne muss OSINT-Risiken verstehen und sich schützen. Die Verantwortung darf jedoch nicht allein den Nutzern zugeschoben werden, da dies Macht- und Wissensunterschiede ignoriert.

Plattform-Verantwortung: Betreiber von sozialen Medien, Suchmaschinen und Datenbrokern tragen eine grosse Verantwortung für das OSINT-Ökosystem, aus dem sie Profit schlagen. Regulierungen fordern zunehmend, dass sie dieser Pflicht nachkommen.

Integration von Sicherheitsbewusstsein

OSINT sollte zentraler Bestandteil von Sicherheitsschulungen in Unternehmen und Bildungseinrichtungen sein.

Mitarbeiter-Schulungen: Mitarbeiter sind potenzielle Ziele und Informationsquellen. Schulungen sollten OSINT-Risiken, Social Engineering-Taktiken und sichere Praktiken beim Informationsaustausch behandeln.

Akademische Integration: Studenten in relevanten Studiengängen (Recht, IT, Cybersicherheit, Datenschutz) benötigen eine umfassende OSINT-Ausbildung, um zukünftige Bedrohungen und Schutzmassnahmen zu verstehen.

HSLU

Schutzmassnahmen und Präventionsstrategien

Zur Minderung von OSINT-Risiken sind proaktive Massnahmen, die technische Kontrollen, Verhaltensanpassungen und kontinuierliche Überwachung kombinieren, erforderlich. Geschichtete Abwehrmechanismen sind am effektivsten.

01

Bewusste Informationsfreigabe

Überlegen Sie genau, welche Informationen Sie öffentlich teilen. Bedenken Sie mögliche Empfänger und zukünftige Kontexte.

02

Metadaten-Reduktion

Entfernen Sie EXIF-Daten aus Fotos vor dem Teilen. Nutzen Sie Werkzeuge wie ExifTool, MAT2 oder integrierte Plattformfunktionen, um sensible Metadaten zu entfernen.

03

Identitäts-Kompartimentierung

Nutzen Sie separate digitale Identitäten für berufliche, private und sensible Kontexte. Verwenden Sie unterschiedliche Benutzernamen, E-Mail-Adressen und Profile, um Korrelationen zu verhindern.

04

Regelmässige Selbst-OSINT-Audits

Führen Sie regelmässig Selbst-OSINT-Audits durch. Suchen Sie nach Ihrem Namen, Benutzernamen, Telefonnummern und E-Mail-Adressen, um potenzielle Datenlecks zu identifizieren.

Passen Sie regelmässig Datenschutzeinstellungen auf Social-Media-Plattformen an. Nutzen Sie datenschutzorientierte Suchmaschinen und Browser. Bei hohem Risiko sollten professionelle OSINT-Bewertungsdienste in Betracht gezogen werden.

Fall Study

Der "harmlose" Post

Eine trügerische Fassade

1

Der Social-Media-Post

@maxhslu teilt seine Freude: "Endlich am Ziel! Perfekter Start in das Auslandssemester 🎉 #UniLife #Barcelona"

Ein typischer Post junger Erwachsener, spontan, emotional, authentisch. Doch was auf den ersten Blick nach harmloser Begeisterung aussieht, ist eine Goldgrube für OSINT-Analysten.

2

Visueller Anker

Das Foto offenbart mehr als beabsichtigt: Markante Architektur ermöglicht präzise Standortbestimmung, Sonnenstand und Schattenwurf verraten die Tageszeit, Spiegelungen in Fenstern liefern zusätzliche Details über die Umgebung.

Moderne Bilderkennungstools können aus diesen visuellen Hinweisen innerhalb von Sekunden den exakten Aufnahmeort bestimmen – oft auf wenige Meter genau.

3

Identitäts-Fragmente

Der Post liefert konkrete Identifikationsmerkmale: Der Standort Nyhavn in Kopenhagen ist eindeutig identifizierbar, der Nutzername @max_m lässt sich plattformübergreifend verfolgen, frühere Posts verraten die Heimat-Universität (FH München).

Die zentrale Frage: Was davon wollte der Nutzer wirklich teilen – und was gibt er ungewollt preis?

🎮 OSINT-Challenge: Vom Pixel zur Person

Interaktives Lernspiel

📍 Standort-Analyse (GEOINT)

Tools:

Aufgabe: Analysieren Sie das Foto aus dem Post von

@maxhslu

geospy.net (KI-basierte Standortbestimmung)
Google Reverse Image Search

Frage: Können Sie den exakten Standort in Barcelona identifizieren?

🔍 Username-Tracking

Aufgabe: Verfolgen Sie @maxhslu über verschiedene Plattformen

Frage: Auf welchen anderen Plattformen ist dieser Nutzer aktiv?

https://namevine.com/#/

Die Kette der Verlinkung

Vom Pixel zur Person

Was als einzelner Post beginnt, entwickelt sich durch systematische OSINT-Methoden zu einem vollständigen Personenprofil. Der Prozess folgt einer präzisen Logik, die öffentlich verfügbare Daten systematisch verknüpft.

Geografische Präzision (GEOINT)

Spezialisierte Tools wie geospy.ai analysieren Fassadenmuster, Strassenverläufe und architektonische Besonderheiten. EXIF-Metadaten in hochgeladenen Fotos liefern GPS-Koordinaten mit einer Genauigkeit von wenigen Metern, Geospy.net..... Reverse Image Search über Google Maps oder Yandex bestätigt die Lokalisierung innerhalb von Minuten.

Kontextuelle Korrelation

Wetterdaten und Schattenanalyse bestätigen den genauen Aufnahmezeitpunkt. Google Maps zeigt Studentenwohnheime im Umkreis von 500 Metern. Öffentliche Universitätsdatenbanken listen Austauschprogramme mit Barcelona. Durch Cross-Referenzierung entsteht ein Zeitfenster und ein wahrscheinlicher Wohnort.

Die Identitäts-Fusion

LinkedIn-Profile mit ähnlichem Nutzernamen liefern den Klarnamen. Fitness-Tracking-Apps wie Strava oder Komoot zeigen regelmässige Laufrouten und damit den tatsächlichen Wohnort. Instagram-Stories, Spotify-Playlists und öffentliche Kommentare vervollständigen das Profil. **Ergebnis: Ein vollständiger Datensatz mit Name, Adresse, Tagesablauf und sozialen Kontakten.**

HSLU

Praktische Anwendung , OSINT



HSLU

Schritt 1: Benutzernamensuche

5 MINUTEN

Tool: Sherlock

Kostenlose, einfache Benutzernamen-Enumeration über Hunderte von sozialen Netzwerken

Option A: Selbsttest

```
maigret maxhslu
```

https://apify.com/store/categories

Typische Ergebnisse, die Sie entdecken werden:

```
[+] GitHub: https://github.com/troyhunt
[+] Twitter: https://twitter.com/troyhunt
[+] Reddit: https://reddit.com/user/troyhunt
[+] HackerNews: Found!
[+] Medium: https://medium.com/@troyhunt
[+] YouTube: Found!
```

Was wir jetzt haben: 5-10 Social-Media-Profile. Dokumentieren Sie für Ihren Selbsttest, wie viele Profile gefunden wurden, welche Sie vergessen hatten und ob alte oder inaktive Konten auftauchten.

HSLU

Schritt 2: Twitter/X-Analyse

10 MINUTEN

Tool: Twitter/X

Für den Selbsttest:

```
https://twitter.com/DeinTwitterHandle
```

Beispiel mit Troy Hunt:

```
https://twitter.com/maxhslu
```



Bio-Informationen

"



Standortdaten

Profil zeigt oft den Standort an (z.B. "Gold Coast, Australien") – sofortige geografische Intelligenz

Externe Links

Oft Links zur persönlichen Website oder Blog, erweitert die Untersuchungsfläche



Netzwerkanalyse

Follower-/Following-Verhältnisse zeigen Einfluss und berufliche Verbindungen

Berücksichtige bei deinem Selbsttest: Was verrät deine Bio? Sind Standortdetails sichtbar? Welche externen Links teilst du? Diese Informationen sind für jeden ohne Authentifizierung zugänglich.

HSLU

Schritt 3: Profilbild-Analyse

10 MINUTEN

Profilbild herunterladen

```
# Rechtsklick auf Profilbild → "Bild speichern unter"
# Datei: profilbild.jpg
```

Tool 1: Google Bildersuche (Rückwärtssuche)

01

Navigieren Sie zu https://images.google.com/

02

Klicken Sie auf das Kamera-Symbol

03

Laden Sie Ihr Profilbild hoch

Was Sie über sich selbst herausfinden können:

- Wo verwenden Sie das gleiche Bild noch?
- Erscheint es auf anderen Plattformen?
- Gibt es ähnliche Bilder von Ihnen?



Beispiel mit einer öffentlichen Person (Troy Hunt): Das Profilbild erscheint auf LinkedIn, GitHub, seiner Website und Rednerlisten von Konferenzen. Zeigt Konsistenz über alle Plattformen hinweg und demonstriert professionelle Wiederverwendung von Bildern.

HSLU

Schritt 4: LinkedIn-Untersuchung

5 MINUTEN

Für den Selbsttest:

01

Öffnen Sie LinkedIn.com

02

Suchen Sie nach Ihrem eigenen Namen

03

Prüfen Sie: Welche Informationen sind öffentlich sichtbar?

Was LinkedIn öffentlich anzeigt (ohne Anmeldung):

- **Name & Berufsbezeichnung:** "Security Researcher bei Have I Been Pwned"
- **Aktueller Arbeitgeber/Unternehmen:** Oft sichtbar
- **Standort:** Stadt/Region
- **Profilbild:** Vollständig sichtbar

Für eine öffentliche Person (Beispiel):

```
site:linkedin.com "Troy Hunt" security
```

Fragen für Ihren Selbsttest: Ist Ihr Profil auf „öffentlich“ eingestellt? Welche Details sollten privat bleiben? Sind Ihre aktuelle Position/Firma für alle sichtbar?



Schritt 5: Instagram-Analyse

10 MINUTEN

Tool: Picuki (keine Anmeldung erforderlich) - `https://www.picuki.com/profile/YourInstagramName`
Alternative: Instagram im Browser (eingeschränkte Ansicht ohne Anmeldung) - `https://www.instagram.com/YourUsername`



Was öffentliche Profile offenbaren:

- **Bio-Informationen**
  - Oft mit Links zu anderen Plattformen, die weitere Untersuchungsansätze bieten
- **Beitragsvolumen**
  - Anzahl der Beiträge deutet auf Aktivitätsniveau und Plattform-Engagement hin
- **Netzwerk-Metriken**
  - Verhältnis von Followern/Gefolgten zeigt Einfluss und soziale Verbindungen
- **Soziales Netzwerk**
  - Markierte Fotos identifizieren Freunde, Kollegen, Familienmitglieder

⚠️ **GPS-Gefahr in Bildern:** Wenn jemand Bilder von ausserhalb Instagrams hochlädt (z.B. direkt von der Kamera), können diese immer noch GPS-Daten enthalten, die genaue Standorte verraten!

Während deines Selbsttests: Ist dein Profil öffentlich oder privat? Verraten deine Bilder deinen Wohnort? Sind Geotags aktiviert? Wer ist auf deinen Bildern markiert?

HSLU

Zusammenfassung: Was Sie über sich selbst herausfinden können

In 55 Minuten: Vom Benutzernamen zum vollständigen digitalen Profil

Persönliche Daten

- **Name:** Oft auf LinkedIn oder anderen Profilen
- **Alter:** Einschätzbar aus Bildungsdaten
- **Standort:** Aus Standort-Tags, Bio, Beiträgen
- **Beruf:** LinkedIn, Twitter-Bio, GitHub-Projekte

Berufsbezogene Informationen

- **Unternehmen:** LinkedIn, E-Mail-Signaturen in GitHub
- **Arbeits-E-Mail:** Git-Commits, öffentliche Repositories
- **Zertifizierungen:** LinkedIn, Twitter-Beiträge

- **Geräte:** EXIF-Daten können Kamera/Smartphone verraten

Soziales Umfeld

- **Interessen:** Aus Reddit, Instagram, Twitter
- **Freunde/Kollegen:** Getaggte Fotos, Erwähnungen
- **Standorte:** Geotags, Check-ins, Fotos
- **Gemeinschaften:** Gruppenmitgliedschaften

Häufige Sicherheitsrisiken

Gleicher Benutzername überall

Leicht über Plattformen hinweg verfolgbar – erstellt einen einheitlichen digitalen Fingerabdruck

GPS-Daten in Fotos

Heimadresse in Metadaten sichtbar – genaue Koordinaten exponiert

Öffentliche Arbeits-E-Mail

Phishing-Ziel – ermöglicht Social-Engineering-Angriffe

Alte Social-Media-Beiträge

Jahrelange Historie – vergangene Aussagen können im Widerspruch zu aktuellen Positionen stehen

HSLU

Schnelle Befehlsübersicht

Nachschlagewerk für essenzielle OSINT-Befehle, die in diesem Workshop verwendet werden. Kopieren Sie diese für zukünftige Ermittlungen.

1. Benutzernamensuche

https://www.kali.org/tools/sherlock/

```
sherlock username
```

Findet Social-Media-Profile auf hunderten von Plattformen.

2. Twitter-Analyse

```
https://twitter.com/username
```

(Eingeschränkte Ansicht ohne Anmeldung)

3. EXIF-Daten lesen

```
exiftool image.jpg
```

Extrahiert alle Metadaten, einschliesslich GPS-Koordinaten.

4. EXIF-Daten entfernen (Schutz)

```
exiftool -all= clean_image.jpg
```

Entfernt alle Metadaten zum Schutz der Privatsphäre.

5. Subdomain-Erkennung

```
subfinder -d company.com
```

Findet Subdomains der Zieldomäne.

6. E-Mail-Sammlung

```
theHarvester -d company.com -
b google,linkedin
```

Sammelt E-Mail-Adressen aus öffentlichen Quellen.



Wann ist OSINT nach revDSG legal?

Rechtfertigungsgrund

- Einwilligung vorhanden
- Überwiegendes Interesse
- Gesetzliche Grundlage

Datenbearbeitungsgrundsätze

- Rechtmässig, Treu & Glauben
- Verhältnismässig
- Zweckgebunden

Besonders schützenswerte Daten

- Sorgfältige Abwägung
- Einwilligung erforderlich
- Erhöhte Anforderungen

Praxisbeispiel: LinkedIn-Profil zur beruflichen Verifikation → in der Regel zulässig bei Due-Diligence-Prüfung (*alle relevanten wirtschaftlichen, rechtlichen und technischen Aspekte des Unternehmens oder Projekts systematisch geprüft werden)*

Wann wird OSINT problematisch?

Legal ✔

- Zweck legitim
- Verhältnismässig
- Transparent
- Mit Rechtfertigung

Illegal ×

- Übermässige Datensammlung
- Zweckänderung ohne Basis
- Massenscraping gegen AGB
- Profiling mit hohem Risiko
- Fehlende Transparenz

Verhältnismässigkeit verletzt

Umfassende Social-Media-Analysen für einfache Bewerbung

Zweckentfremdung

Öffentliche Fotos für Profiling oder kommerzielle Zwecke

Informationspflicht missachtet

Betroffene werden nicht informiert trotz rechtlicher Verpflichtung

HSLU

Ethische Grenzen

Rechtlich und erlaubt:

- Öffentlich zugängliche Social-Media-Profile
- Google-Suchen und öffentliche Suchmaschinen
- Öffentliche Archive und Datenbanken
- EXIF-Daten von selbst heruntergeladenen Bildern

Illegal und verboten:

- Passwort-Cracking oder Brute-Force-Angriffe
- Erstellen gefälschter Profile zur Täuschung
- Stalking- oder Belästigungsaktivitäten
- Doxing (Veröffentlichung privater Daten mit böswilliger Absicht)
- Identitätsdiebstahl oder Nachahmung

Grauzone (kontextabhängig):

Diese Aktivitäten können je nach Gerichtsbarkeit, Zweck und Umsetzung legal sein:

- **Scraping grosser Datenmengen:** Nutzungsbedingungen können dies verbieten
- **Aggregation aus vielen Quellen:** Legal, aber potenziell ethisch fragwürdig
- **Kommerzielle Nutzung von Daten:** Kann je nach Datenschutzgesetzen eine Einwilligung erfordern
- **Automatisierte Datenerfassung:** Überprüfen Sie Plattformrichtlinien und lokale Vorschriften

Professioneller Standard: Berücksichtigen Sie stets den Zweck, die Verhältnismässigkeit und den potenziellen Schaden Ihrer Ermittlungen. Nur weil Sie Informationen finden können, heisst das nicht, dass Sie sie auch verwenden sollten.

HSLU

Wichtige Kernbotschaft

"Ein einzelner Benutzername oder ein Profilbild kann innerhalb weniger als einer Stunde mit kostenlosen Tools zu einem vollständigen digitalen Profil führen."

Bewährte Praktiken für digitale Hygiene:



Diverse Benutzernamen

Verwenden Sie unterschiedliche Benutzernamen für verschiedene Plattformen, um plattformübergreifendes Tracking und Korrelationen zu verhindern.



EXIF-/GPS-Daten entfernen

Entfernen Sie Metadaten aus Fotos, bevor Sie sie hochladen, um die Offenlegung von Standorten zu verhindern.

Datenschutzeinstellungen überprüfen

Überprüfen Sie regelmässig die Datenschutzeinstellungen auf allen Plattformen – Standardeinstellungen begünstigen oft die Sichtbarkeit.



Ego-Searching durchführen

Googeln Sie sich regelmässig selbst, um Ihren öffentlichen digitalen Fussabdruck zu verstehen.

HSLU

Nächste Vorlesung SW3

Identität, Schutzziele



Vielen Dank

Hochschule Luzern – Informatik

Fragen und Diskussion sind jederzeit willkommen. Die Unterlagen und weiterführende Materialien finden Sie auf ILIAS.